

丰智云链（SF-SCM）供应链管理平 台 应用安全检测报告

初测

委托单位：东风汽车股份有限公司

测试人员：兰浩淼

测试日期：2026 年 07 月 20 日

深圳联友科技有限公司湖北分公司

检测概述

背景介绍

随着国内外网络安全形势日益严峻，攻防不对等拉锯，网络攻击入侵门槛不断拉低，同时网络安全法的落地实施，国家监管层面不断加大信息系统安全监管及处罚力度。一旦信息系统应用软件存在安全漏洞、配置不规范或业务安全风险，易遭受到网络安全攻击，给应用系统的稳定运行、数据安全带来了极大的风险隐患，信息系统的安全已经成为了目前迫切亟待解决的问题。

为进一步加强网络安全管理与数据安全保护，切实防范信息安全风险，依据国家（行业）标准和监管合规要求，对目标系统 <http://内网 IP:8003/fp/>（经授权内网穿透访问，已脱敏）开展应用安全检测，全面识别应用系统面临的安全风险隐患，包含业务安全风险，及时采取相应的技术措施进行安全防范和修复加固，降低攻击入侵，提升业务系统安全健壮性，保障业务系统安全运行。

参考标准

此检测报告引用以下标准与规范（版本于报告编制时经官方来源核对，均为现行有效版本，并结合被测对象所属行业选取相关项）：

- 《OWASP 安全测试指南 V4.0》
- 《OWASP TOP10》
- 《渗透测试执行标准 PTES（Penetration Testing Execution Standard）》
- 《ISO/IEC 27001 信息安全管理》
- 《GB/T 30279-2020 信息安全技术 网络安全漏洞分类分级指南》
- 《GB/T 30276-2020 信息安全技术 网络安全漏洞管理规范》
- 《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
- 《GB/T 40856-2021 车载信息交互系统信息安全技术要求及试验方法》
- 《汽车数据安全若干规定（试行）》
- 《中华人民共和国网络安全法》
- 《中华人民共和国数据安全法》
- 《中华人民共和国个人信息保护法》

注：上述标准每次执行检测前应重新核对是否有更新版本。

适用说明

针对软件应用（含移动服务端、C/S 服务端等）开展应用安全检测，本次被测对象为 丰智云链（SF-SCM）供应链管理平台，不涉及主机、配置等其他检测。

工作原则

开展安全检测应遵循的工作原则是：

(1) 规范性原则

安全检测过程有统一的流程，安全检测中使用的方法及使用的文档，需要具有很好的规范性，便于安全检测工作的质量保证，并保证结果的一致性。

(2) 可控性原则

安全检测所使用的工具、方法和过程要在双方认可的范围之内，安全检测的进度要符合进度表的安排，保证双方对安全检测的可控性。

(3) 整体性原则

安全检测的范围和内容应当系统性、全面，覆盖信息系统安全所涉及的各个层面，并考虑各个层面的相互关系。

(4) 最小影响原则

安全检测应尽可能较小的影响网络和系统的正常运行，不能对系统的业务产生显著影响，避免造成被测评系统的性能明显下降、网络拥塞、服务中断等；不删除或修改数据、不触发破坏性操作、不进行高强度爆破、不执行破坏性注入类测试。

(5) 保密性原则

对在安全检测中所接触到的用户单位的所有敏感信息，检测人员应遵循相关的保密承诺，不利用相关信息进行任何侵害被检测单位安全利益的行为。本报告不含口令、完整 Cookie、令牌等敏感原文。

检测内容

该检测报告用于应用系统安全检测，可覆盖已上线前安全检测、上线后安全检测、安全评估、互联网安全检测等场景，包含端口安全、基线安全、前端安全、传输安全、身份鉴别、权限管理、会话安全、密钥安全、异常处理、业务安全、日志审计、数据安全、常见漏洞等 13 个大类，共计 55 项安全检测内容。

检测工具

安全检测工具清单如下（当前列举为本次实际使用的主要工具，结合不同应用类型和漏洞组件验证，会使用到其他检测工具）：

工具名称	工具类型	工具用途
浏览器 + 开发者工具	手工检测	页面/JS/Cookie/请求响应观察取证、真实登录深测
curl	手工检测	HTTP 请求构造、响应头/CORS/HTTP 方法验证
cpolar	内网穿透	经授权将内网应用端口安全

		暴露供检测
--	--	-------

检测声明

安全检测在应用系统上线前开展，如测试环境和生产环境一致，宜使用测试环境开展，如测试和生产差异较大，两套环境应同时开展检测，检测前应确保应用所有组件部署完成，并提供生产和测试环境所有资产信息。

本报告为本次应用安全检测服务的输出结果，供业务方进行漏洞修补和安全加固参考，并进行安全风险规避，安全控制和管理。

本报告的检测结论仅对被测对象当时的状态有效。当检测完成后，由于被测对象的系统变更，本报告不再适用。

在任何情况下，若需引用本报告中的结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。

变更记录

时间	版本	说明	修改人
2026-07-20	V1.0	创建应用安全检测报告	兰浩淼

检测结果

检测信息

项目名称	系统级别	应用网址	IP 地址
丰智云链（SF-SCM）供应链管理平台	等保二级（待核定）	http://内网 IP:8003/fp/（经授权内网穿透访问，已脱敏）	内网访问（脱敏）

风险信息

本次安全检测共完成 55 项检测内容，共计发现 15 个安全风险，其中高危风险 1 个、中危风险 14 个（判定为“不符合”）。另有“符合” 32 项、“未测试” 6 项、“不涉及” 2 项。

“未测试” 6 项系因测试条件受限（如缺少对照账号、生产环境非破坏性约束、经隧道无法验证等）无法完成验证，据实标记并说明原因；“不涉及” 2 项系统不涉及对应功能场景。

风险汇总

序号	风险章节	风险名称	风险等级	复测结果
1	3.3.1	前端 JS 库软件	中	

		版本安全测试		
2	3.3.2	前端泄露风险测试（如JS）	中	
3	3.4.2	防重放攻击、防篡改功能安全测试	中	
4	3.5.3	双因素验证功能（短信或邮件等）安全测试	中	
5	3.5.4	首次登录强制改密安全测试	中	
6	3.5.9	长期不登录账号锁定安全测试	中	
7	3.7.1	Cookie 安全测试	中	
8	3.7.2	CORS 跨域资源共享安全测试	中	
9	3.7.4	会话超时安全测试	中	
10	3.7.5	会话标识安全测试	中	
11	3.8.2	AK/SK 专项安全测试	中	
12	3.12.1	加密传输安全测试	高	
13	3.12.2	数据脱敏展示安全测试	中	
14	3.13.1	HTTPS 安全测试	中	
15	3.13.16	敏感信息泄露安全测试	中	

注：上表仅列出本次判定为“不符合”的 15 项风险；全部 55 项检测内容的逐项结果（含符合/未测试/不涉及）详见“检测详情”。“复测结果”列供整改复测时填写。

检测详情

端口安全

应用端口服务安全测试

测试编号	PORT-001
风险名称	应用端口服务安全测试
风险等级	—
功能要求	排查应用高危端口可直接访问等风险，如排查应用或服务管理端（包含不限于

	网络安全设备、云平台、虚拟化平台、大数据平台、邮件管理端、通用类应用管理端等）端口是否限制直接访问、tomcat ajp 协议是否做隔离等风险。 对于三级系统以及重要业务系统，如车联网系统、营销系统等，要求业务端和管理端进行端口分离。 3、对于三级系统以及重要业务系统，如车联网系统、营销系统等，管理端端口应进行 IP/IP 段（范围不易过大）白名单访问限制。
风险影响	攻击者通过高危端口对应用服务开展漏洞利用攻击行为，获取应用服务权限并造成敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	经授权内网穿透（cpolar）访问目标应用，实测对外仅提供 HTTP 应用端口（8003）承载业务；对 /actuator、/actuator/env、/swagger-ui.html、/v2-3/api-docs、/druid/index.html 等常见管理端点探测，返回均为 SPA 前端 index.html（Content-Type: text/html，非真实端点），未发现多余管理/监控端口对外暴露。
修复建议	
备注	经隧道仅能观测应用业务端口，云端无法对内网主机做全端口段扫描，全端口扫描未覆盖。

基线安全

应用软件及相关组件版本基线安全测试

测试编号	BASIC-001
风险名称	应用软件及相关组件版本基线安全测试
风险等级	—
功能要求	应用软件开发框架、中间件和其他应用组件等，应满足安全基线要求
风险影响	低版本组件存在安全漏洞，攻击者利用漏洞可获取敏感信息或服务器应用权限
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	响应头 Server 仅为 openresty，未回显具体版本号；未发现 actuator/swagger/druid 等组件管理台对外可用；未在响应中发现中间件/框架精确版本、构建路径等基线信息泄露。
修复建议	
备注	后端具体框架/中间件版本无法从对外响应可靠获取。

前端安全

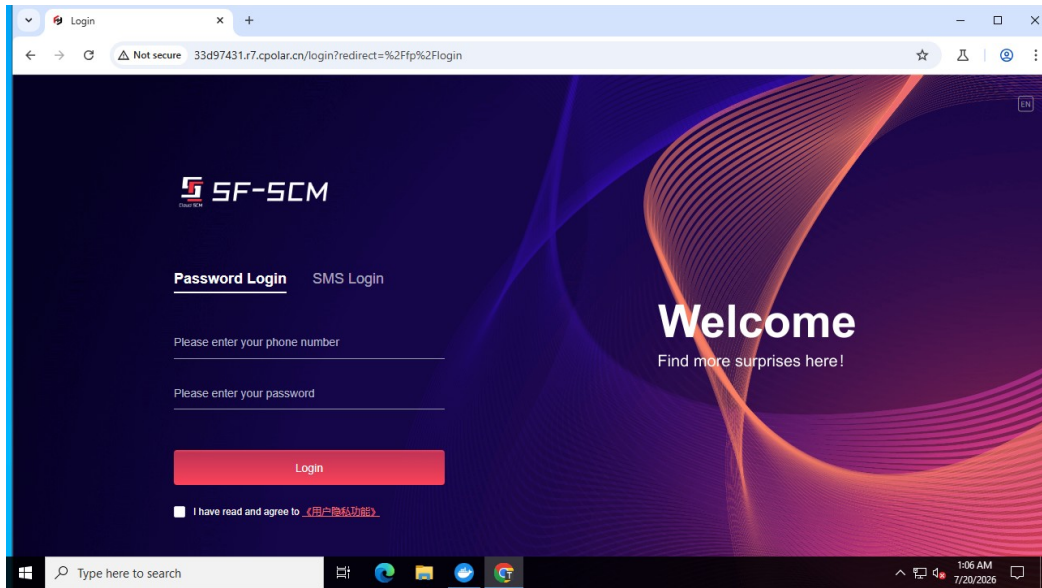
前端 JS 库软件版本安全测试

测试编号	FRON-001
风险名称	前端 JS 库软件版本安全测试
风险等级	中

功能要求	前端应使用满足基线版本的 JavaScript 库版本
风险影响	低版本的 JavaScript 库存在已知安全漏洞，这些漏洞可能允许攻击者在用户浏览网页时执行恶意操作，如窃取用户数据、操纵页面内容、发起跨站脚本攻击 (XSS)、执行服务器端请求伪造 (SSRF)、进行点击劫持或其他形式的攻击手段
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	前端生产 bundle (base-sys/main.e526ec63.js) 中内嵌 axios 组件的 package 元数据，明确标注 "name":"axios","version":"0.21.4"，即前端使用 axios 0.21.4 (2021 年发布的旧版本)。该版本存在已知中危漏洞 CVE-2023-45857 (GHSA-wf5p-g6vw-rhxx，影响 axios <1.6.0)：在跨源重定向场景下会将 XSRF-TOKEN 泄露给第三方主机。
修复建议	将 axios 升级至 $\geq 1.6.0$ ；同步梳理前端第三方依赖清单并纳入 SCA 组件漏洞例行扫描。
备注	版本经 bundle 内 axios package.json 元数据确证；其余库经生产混淆未能可靠取版，未逐一比对。

前端泄露风险测试（如 JS）

测试编号	FRON-002
风险名称	前端泄露风险测试（如 JS）
风险等级	中
功能要求	前端 JS 文件应不包含敏感信息，如接口、密钥、个人敏感信息、应用敏感信息等
风险影响	前端 JS 文件中的存在敏感信息可能被攻击者探测获取，造成敏感信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	分析前端 env.js 与主 bundle：env.js 明文暴露内部微服务路由前缀（/base-sys/、/fx-sys/ 等）；bundle 内硬编码内部对象存储服务地址（顺丰 OSS 外网/SIT 域名）与高德地图 Web API Key（32 位十六进制，已脱敏）。上述信息可为攻击者刻画内部服务结构、复用第三方配额提供便利。
修复建议	前端仅暴露必要的运行时配置；内部服务地址、第三方 Key 等敏感配置改由后端下发或按域名/来源做访问限制；对第三方地图 Key 配置 Referer/域名白名单与配额告警。
备注	未发现前端硬编码账号口令或私钥。



图：应用前端登录页（HTTP 明文，浏览器提示 Not secure）

传输安全

软件版本信息泄漏安全测试

测试编号	TRAN-001
风险名称	软件版本信息泄漏安全测试
风险等级	—
功能要求	应用服务不应泄露软件版本信息。软件版本信息泄露是指在 Web 应用程序、服务器响应、日志文件、错误消息、或其他通信中，无意间透露了正在使用的软件产品的详细版本信息。
风险影响	如果泄露的版本是一个已知存在严重漏洞的版本，攻击者可以迅速识别出目标系统可能存在的安全隐患，从而更容易发动攻击，获取应用服务权限，产生敏感信息泄露的风险。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	对外响应头 Server 仅为 openresty，未携带精确版本；页面与接口响应未见框架/中间件精确版本信息泄露。
修复建议	
备注	

防重放攻击、防篡改功能安全测试

测试编号	TRAN-002
风险名称	防重放攻击、防篡改功能安全测试
风险等级	中

功能要求	1、请求应具备防重放攻击防护,防止攻击者截取请求,利用重放方式持续进行漏洞探测 2、请求应具备防篡改攻击防护,即对请求包进行签名保护,防止被恶意篡改 3、针对核心系统(如营销、车联网、邮件等系统),集权系统(如监控平台、云平台)和三级及以上系统,应对请求包和响应包双向做防篡改防护,可通过签名、时间戳、随机数等技术措施,防止被恶意篡改 4、针对核心系统(如营销、车联网、邮件等系统),集权系统(如监控平台、云平台)和三级及以上系统,如果存在签名被绕过,应用软件应对隐藏域的参数进行校验
风险影响	攻击者截取请求和响应,利用重放、篡改方式持续进行漏洞探测,可能产生代码执行、权限绕过、敏感信息泄露等各类风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	抓取真实业务接口请求(如 GET /api/user-center/users/getUser)观察:请求未携带时间戳、随机数(nonce)或请求签名等防重放/防篡改参数;会话令牌为长期有效的 opaque UUID,可被重复提交而不失效。登录环节虽含一次性行为验证码参数,但业务接口整体缺乏防重放与完整性保护。
修复建议	对关键业务接口引入时间戳 + nonce + 服务端校验的请求签名机制,或对敏感操作使用一次性 token;缩短令牌有效期。
备注	

身份鉴别

验证码功能安全测试

测试编号	AUTH-001
风险名称	验证码功能安全测试
风险等级	—
功能要求	1、应用系统登录认证(包含应用后台管理)应包含图形码验证功能。考虑用户体验,可弹性使用图形码(例如首次验证不使用图形码,在验证失败后,再辅助图形码进行验证)或滑块验证等 2、验证码应在服务后端进行验证 3、完善验证码检验机制,避免空参数绕过 4、每次进行登录认证,无论认证是否成功,验证码都应自动刷新 5、三级应用系统应使用双因素认证加随机验证码
风险影响	存在账密爆破风险,攻击者破解窃取应用账号,导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	登录页启用行为式滑块验证码(极验类,请求含 captcha_id / lot_number / pass_token / captcha_output 等参数),由服务端校验通过后方可提交登录,具备人机识别能力。
修复建议	
备注	

账号注册、密码找回及改密功能安全测试

测试编号	AUTH-002
风险名称	账号注册、密码找回及改密功能安全测试
风险等级	—
功能要求	1、应通过管理员在后台进行账号开通（集成 IAM 系统，可通过 IAM 改密模块操作），如在账号自行注册的场景里，要有复杂验证码或其他人机验证功能，防止账号批量注册行为，及账号猜测攻击，包含管理员账号 2、在改密时需要输入原密码进行验证（使用 IAM 模块满足改密要求），并且所有密码信息带*模糊显示，并且改密完成后，应注销会话强制重新登录。 3、修改密码不能为最近 5 次曾使用密码 4、账号注册、账号注销、账号改密、密码找回应记录日志留存
风险影响	存在账号批量注册攻击、账号猜测攻击风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	系统不开放自助注册，账号由管理员在“账户管理”中创建；改密/找回流程需短信验证码（观测到 /login/sendModifyPasswordVc、/login/modifyPassword、checkModifyPasswordVc 等接口），流程受控。
修复建议	
备注	改密/找回全链路未逐一破坏性验证。

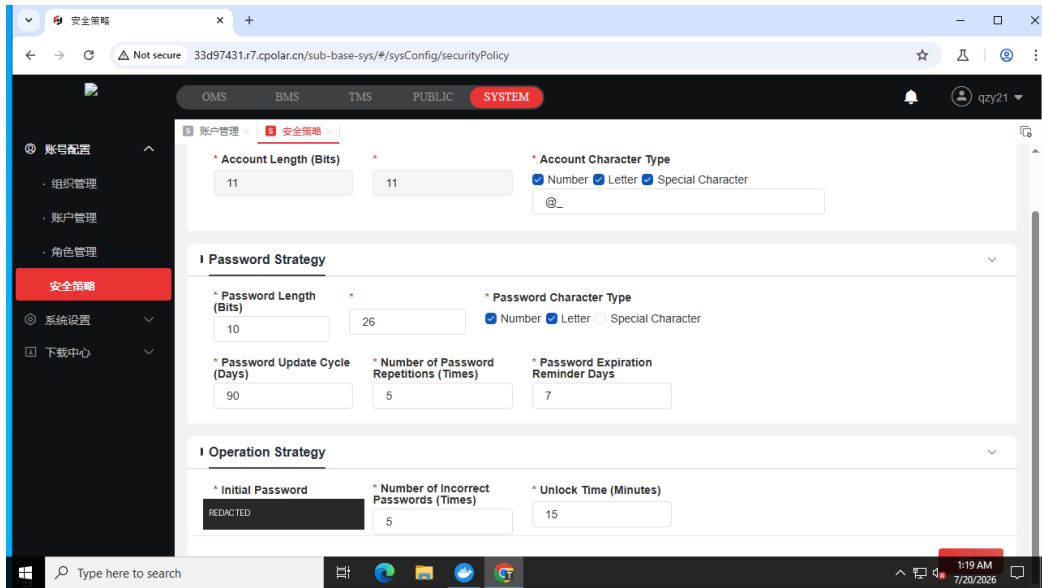
双因素验证功能（短信或邮件等）安全测试

测试编号	AUTH-003
风险名称	双因素验证功能（短信或邮件等）安全测试
风险等级	中
功能要求	涉及使用短信及邮件模块进行验证，应满足以下安全要求： 1、每个账号只允许每隔 60s 发送一次短信、邮件验证信息 2、每个账号发送短信、邮件验证信息在 120s 有效 3、每个账号发送短信、邮件验证码要求不小于 6 位，其中邮件通过链接验证，需在链接中添加临时 token 进行验证，临时 token 有效期在 30min 内 4、每个账号每日发送短信、邮件验证信息最多不超过 10 次 5、短信、邮件验证码一次性有效（即使用完后失效） 6、短信、邮件验证码应后台发送，不能直接通过响应包直接返回用户 7、业务系统应接入 IAM，并开启双因素验证（面向 C 端由安全主任审核通过可例外）
风险影响	存在短信轰炸、资源枯竭、验证码预测与复用的攻击风险，攻击者通过不断重放短信及邮件发生请求，进行短信及邮件炸弹攻击，消耗服务器资源，影响用户体验
测试依据	《OWASP Web Security Testing Guide v4.2》

测试结果	不符合
截图说明	系统提供“短信登录”与短信验证码能力（/login/sendLoginVerificationCode），但以租户管理员账号进行“密码登录”时，仅需口令 + 图形行为验证码即可完成认证，未强制第二因素（短信/邮件）。图形验证码不构成独立的第二认证因素。
修复建议	对管理员等高权限账号强制启用双因素认证（登录口令 + 短信/邮件/OTP）。
备注	

首次登录强制改密安全测试

测试编号	AUTH-004
风险名称	首次登录强制改密安全测试
风险等级	中
功能要求	1、用户使用初始化密码（包括管理员分配的密码）在进行首次登录时，应用应强制要求用户修改密码，密码长度一般不应小于8个字符且应包含大小写字母、数字和特殊字符中的至少三种。 2、对于三级系统，如果初始账号长时间未登录（建议在1个月内），应采取账号自动锁定措施，并记录日志
风险影响	存在数据泄露风险。应用可能出现大量账号使用同一初始密码，攻击者可以通过社工等手段获取初始密码后导致数据泄露。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	“安全策略-操作策略”配置了固定且可预测的初始口令（形如 Fyp@2026***，已脱敏），新建账号统一使用该初始口令；登录后用户信息 needModifyPassword 字段为空，未观察到强制首次改密约束，存在初始口令被猜测/横向复用风险。
修复建议	取消固定初始口令，改为一次性随机口令并通过安全渠道下发；强制用户首次登录必须修改口令后方可使用系统。
备注	



图：安全策略-操作策略（初始口令已脱敏，失败锁定 5 次/解锁 15 分钟）

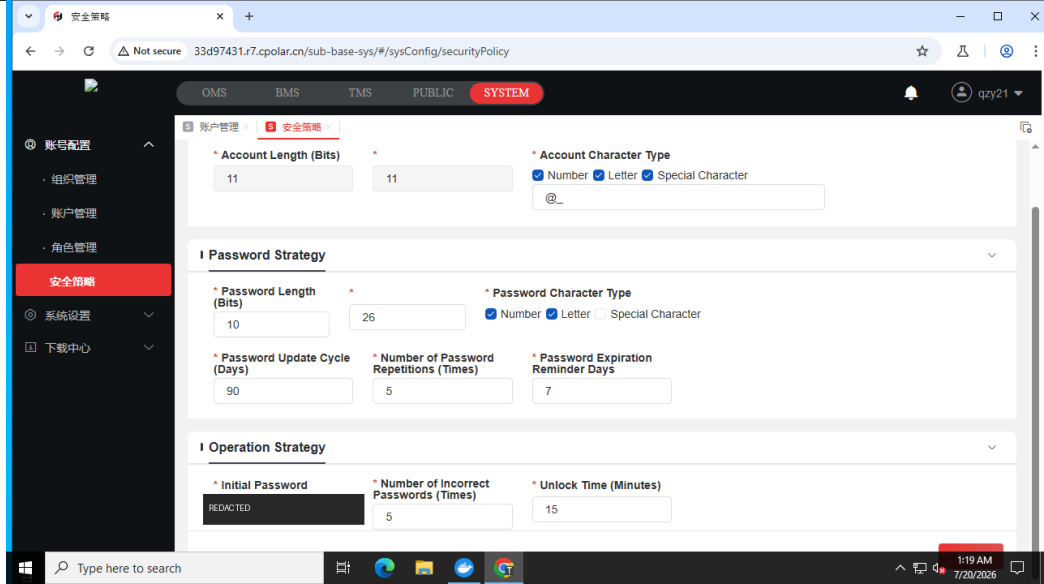
身份验证失败处理安全测试

测试编号	AUTH-005
风险名称	身份验证失败处理安全测试
风险等级	—
功能要求	系统登录失败提示语句因进行统一模糊说明
风险影响	存在应用敏感信息泄露风险，系统登录失败提示语句不一致，攻击者通过提示语句进行账密爆破，破解窃取应用账号从而导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	以错误口令登录时，系统返回统一模糊提示“用户名或密码错误”，未区分“账号不存在/口令错误”，可降低账号枚举风险；并配合失败锁定策略（见 AUTH-006）。
修复建议	
备注	

账号多次失败登录锁定安全测试

测试编号	AUTH-006
风险名称	账号多次失败登录锁定安全测试
风险等级	—
功能要求	1、应用应设置账号多次登录失败锁定账号，并且锁定账号在一定时间内自动解锁 2、三级系统应在 5 次输错图形码情况下，也应联动锁定账号，并且锁定账号在一定时间内自动解锁

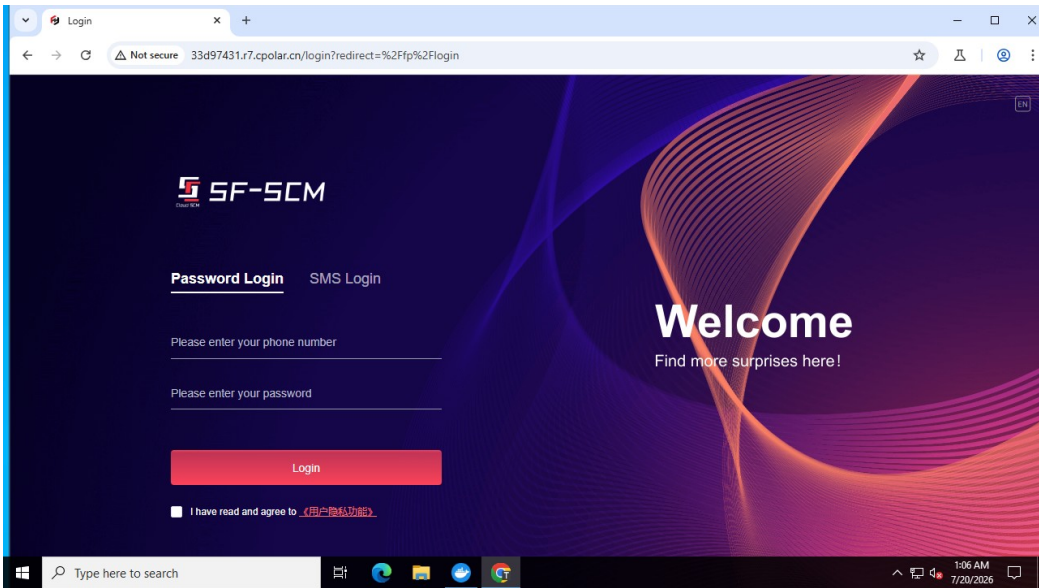
	3、在 3.5.3 相关措施无法有效落实的情况下，对超过 10 次发送短信或邮件验证信息，应联动锁定账号，并且锁定账号在一定时间内自动解锁
风险影响	存在账密爆破风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	“安全策略-操作策略”已启用登录失败锁定：连续错误次数上限 5 次，锁定解锁时间 15 分钟，可有效抑制在线口令爆破。
修复建议	
备注	



图：登录失败锁定策略（5 次 / 15 分钟）

登录密码禁止明文展示安全测试

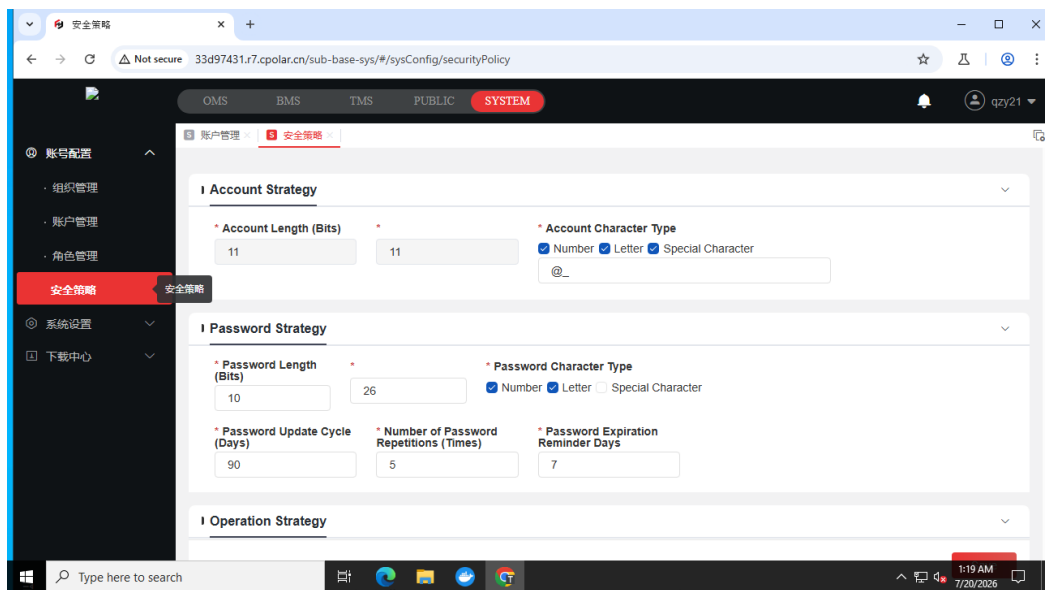
测试编号	AUTH-007
风险名称	登录密码禁止明文展示安全测试
风险等级	—
功能要求	在登录界面、改密界面、账号注册等场景下，输入密码时应禁止使用明文显示，可允许短时间明文查看密码，或明文查看部分密码位数
风险影响	存在账密泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取账号密码，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	登录页口令输入框默认以掩码（type=password）显示，提供“眼睛”图标由用户主动切换明/暗文，默认不明文展示。
修复建议	
备注	



图：登录页口令默认掩码显示

强密码策略安全测试

测试编号	AUTH-008
风险名称	强密码策略安全测试
风险等级	—
功能要求	1、系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种 2、三级系统应具备伪强密码检测模块
风险影响	存在敏感信息泄露风险，用户使用如 123456 等弱口令密码，这类密码极易被攻击者猜测破解从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	“安全策略-口令策略”已启用强口令要求：最小长度 10、需包含数字与字母、口令更新周期 90 天、历史口令不可重复 5 次、到期提醒 7 天。
修复建议	
备注	口令字符类型未强制“特殊字符”，为可优化点。



图：安全策略-口令策略（最小长度 10 / 90 天更新 / 历史 5 次）

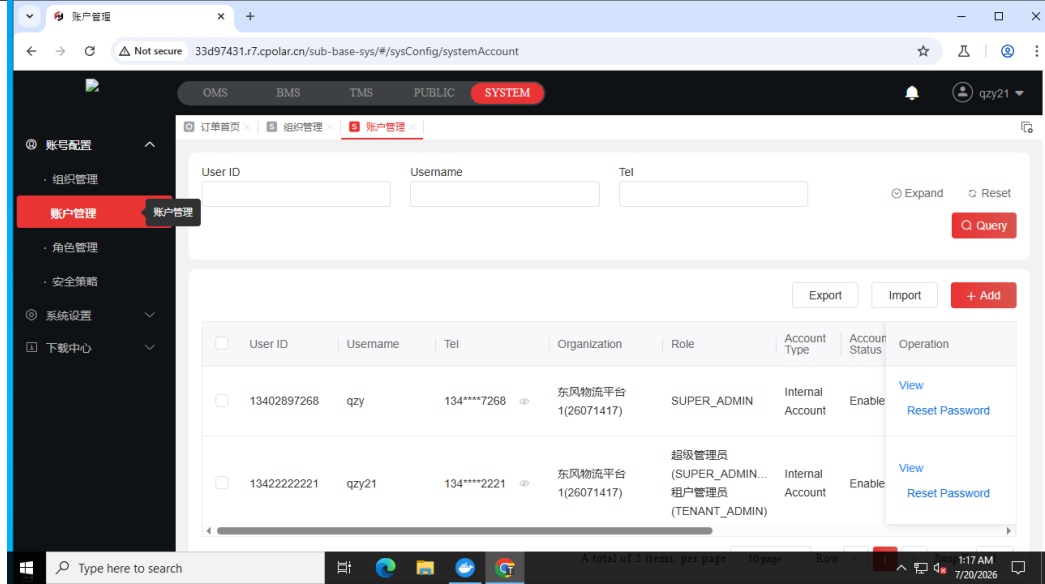
长期不登录账号锁定安全测试

测试编号	AUTH-009
风险名称	长期不登录账号锁定安全测试
风险等级	中
功能要求	应用账号半年不登录自动锁定
风险影响	存在应用敏感信息泄露风险，应用可能出现不再使用却仍保有高度权限的幽灵账号，由于没有人定期更新该类账号的密码，账号可能会被攻击者破解窃取，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	逐页检查“安全策略”各配置页，仅见登录失败锁定、口令更新周期等策略，未见“长期未登录自动锁定/停用”机制或配置项；账户模型虽含 expireDate（固定失效时间）与 loginCount 字段，但无基于不活跃天数的自动停用策略，久未登录的僵尸账号可长期保持可用。
修复建议	增加长期未登录（如 90 天）自动停用/锁定策略，并对休眠账号定期清理或二次确认。
备注	基于被测角色可见的全部安全策略页与账户字段判定；若平台层另有隐式机制，需平台超管复核。

用户标识、角色标识安全测试

测试编号	AUTH-010
风险名称	用户标识、角色标识安全测试
风险等级	—

功能要求	不应在传输过程中带用户标识（如userid、供应商id）、角色标识，应通过cookie、token进行交互验证，userid、供应商id在后端和对应cookie、token进行关联授权 若有传输需要，项目组须提供必要性说明。
风险影响	存在应用敏感信息泄露风险，攻击者通过修改遍历用户标识、角色标识，提升账号权限、越权获取应用敏感数据，导致信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	登录后用户信息含唯一用户标识（id、userName、userCode/手机号）与明确角色标识（roleCode: TENANT_ADMIN / SUPER_ADMIN），“角色管理”模块对角色进行统一定义，用户与角色标识清晰。
修复建议	
备注	



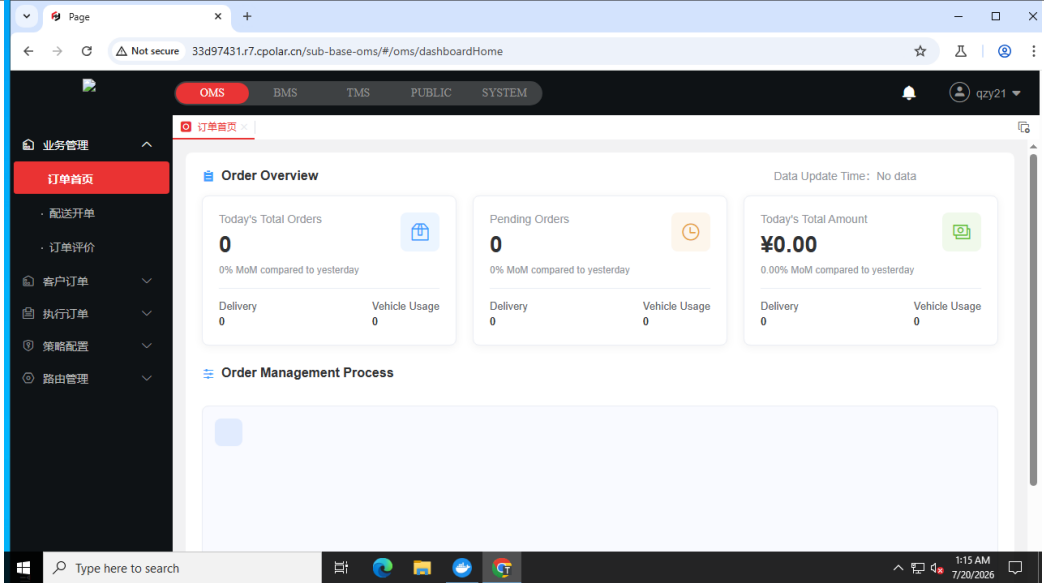
图：账户管理-用户与角色标识（SUPER_ADMIN / TENANT_ADMIN）

权限管理

权限控制功能安全测试

测试编号	PER-001
风险名称	权限控制功能安全测试
风险等级	—
功能要求	1、系统应具备账号赋权功能，可控制任意账户可以访问与操作的资源 2、系统至少具备管理员账户、普通账户两类角色，该两类角色权限应分开 3、管理员应具备对账号进行冻结（锁定）功能，在用户登录、操作异常或被攻击成功等场景下，可直接对账号进行冻结 4、具备操作审计和监控功能，以便及时发现和追踪管理员的恶意操作。

风险影响	存在权限滥用与恶意操作风险，管理员权限过大时，容易引发权限滥用的问题，如随意修改系统配置、删除重要数据等； 存在敏感信息泄露风险，管理员用户没有账号冻结功能，可能导致发生账号泄露事件时，不能及时冻结账号止损。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	系统实现基于角色的访问控制：登录后按角色下发资源/菜单（观测到 /entRoleEntity/getUserResource、getUserResourceModule），不同角色可见的 OMS/BMS/TMS/SYSTEM 菜单与功能不同，具备权限控制能力。
修复建议	
备注	



图：真实登录后按角色加载的业务控制台

防越权安全测试

测试编号	PER-002
风险名称	防越权安全测试
风险等级	—
功能要求	系统应具备更严格的权限管理，防止出现越权问题
风险影响	存在未授权访问与越权操作风险，攻击者利用应用权限管理漏洞，提升账号权限、越权获取应用敏感数据，导致信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	低影响主动验证多个维度未发现越权：①对账户分页接口 POST /api/user-center/account/pageAccount 注入客户端 tenantCode (00000000、%)，服务端一律忽略客户端 tenantCode、仅按令牌所属租户返回本租户账号，横向跨租户越权未奏效（租户隔离有效）；②未授权访问受保护接口返回 401（见

	VULN-015)；③按角色下发菜单/资源（见 PER-001）。残留提示：仅有单一账号，无法对逐业务对象 id 做完整水平越权对照；且观测到租户管理员对同租户 SUPER_ADMIN 账号存在“重置密码”入口（潜在纵向越权设计风险，遵循最小影响未实际执行）。
修复建议	
备注	抽样与租户隔离验证通过判定为符合；完整水平越权对照需第二个（普通用户/其它租户）账号，重置密码设计风险建议业务方复核。

会话安全

Cookie 安全测试

测试编号	SESS-001
风险名称	Cookie 安全测试
风险等级	中
功能要求	Cookie 应启用 Secure 标识以及 HttpOnly 标识 如果一个 Cookie 缺少 Secure 标识，则浏览器允许它通过非加密的 HTTP 连接发送，这意味着这些信息可能以明文形式在网络中传输，增加了数据泄露的风险。攻击者一旦截获，可能冒充用户身份，进行非法操作，如账户接管、数据篡改等。设置附加的 secure 标识来提示浏览器只能通过 Https 来传输 cookie HttpOnly 标识可以阻止浏览器将 Cookie 暴露给客户端脚本（如 JavaScript）。没有此标识的 Cookie 在遭受 XSS 攻击时，攻击者可以通过注入恶意脚本访问到这些 Cookie。一旦攻击者获取到包含会话标识或其他敏感信息的 Cookie，可以冒充用户进行未经授权的操作，如账户劫持、数据窃取等
风险影响	1、存在数据篡改的风险，如果 Cookie 缺少 Secure 标识，则浏览器允许它通过非加密的 HTTP 连接发送，攻击者可以截获 Cookie，冒充用户身份，进行非法操作，如账户接管、数据篡改等 2、存在数据泄露的风险，如果 Cookie 缺少 HttpOnly 标识，在遭受 XSS 攻击时，攻击者可以通过注入恶意脚本访问到这些 Cookie，可以冒充用户进行未经授权的操作，如账户劫持、数据窃取等
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	系统未使用带安全属性的 Cookie 承载会话，认证令牌改存于浏览器 localStorage（键 token、JSESSIONID、__user_info_cache__.accessToken 等），不具备 HttpOnly / Secure / SameSite 等 Cookie 安全防护，令牌可被同源 JavaScript 读取。
修复建议	会话凭证优先采用 HttpOnly + Secure + SameSite 的 Cookie 承载；如确需前端持有令牌，应缩短有效期并配合严格的 XSS 防护与 CSP。
备注	

CORS 跨域资源共享安全测试

测试编号	SESS-002
------	----------

风险名称	CORS 跨域资源共享安全测试
风险等级	中
功能要求	系统应正确配置 CORS，避免出现 CORS（跨域资源共享）源验证失败问题
风险影响	错误的 CORS 配置会导致数据泄露、未授权的资源访问等风险，安全问题如下： 1、恶意跨域请求，即便页面只允许来自某个信任网站的请求，但是它也会收到大量来自其他域的跨域请求。这些请求有时可能会被用于执行应用层面的 DDOS 攻击，并不应该被应用来处理 2、内部信息泄漏，假定一个内部站点开启了 CORS，如果内部网络的用户访问该内部站点的同时也访问了恶意网站，恶意网站可以通过 CORS（跨域请求）来获取到内部站点的内容 3、成功利用 CORS 错误配置的影响还包括：操纵或窃取受害者的 cookie，创建和执行无效请求，在易受攻击的 web 服务器中执行恶意代码，接触敏感信息，安装恶意软件，跨站点脚本攻击等 为了有效防范 CORS 跨域资源共享漏洞，应用应遵循以下要求： 1、关闭非正式开启的 CORS 2、白名单限制：定义“源”的白名单，避免使用正则表达式，不要配置 Access-Control-Allow-Origin 为通配符*或 null，严格校验来自请求数据包中 Origin 的值 3、避免将 Access-Control-Allow-Credentials 标头设置为 true，跨域请求若不存在必要的凭证数据，就根据实际情况将其设置为 false
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	实测接口跨域策略存在配置缺陷：对任意来源（测试 Origin: https://evil.example.com）响应均回显 Access-Control-Allow-Origin 为该来源，且同时返回 Access-Control-Allow-Credentials: true；预检 OPTIONS 亦放行。若结合 Cookie 会话将被恶意站点携带凭证跨域读取数据。
修复建议	取消对任意 Origin 的回显，改为服务端可信来源白名单精确匹配；Allow-Credentials 仅对白名单来源开启，避免与通配/回显来源组合。
备注	当前认证令牌经 Authorization 头传递（非 Cookie 自动携带），实际可利用性有所降低，但配置本身不合规。

会话登出功能安全测试

测试编号	SESS-003
风险名称	会话登出功能安全测试
风险等级	—
功能要求	系统功能应经过登录认证后才能访问，退出登录后会话应立即销毁
风险影响	退出登录后服务端未销毁会话，攻击者可复用登出前的会话凭据继续访问受保护功能，导致会话劫持与越权访问。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	系统提供登出功能（右上角账号菜单“退出”，对应 /sys/logout、/buac/logout 等接口），用户可主动结束会话。

修复建议	
备注	服务端令牌登出后是否即时失效未做进一步破坏性验证。

会话超时安全测试

测试编号	SESS-004
风险名称	会话超时安全测试
风险等级	中
功能要求	所有应用程序应实现会话空闲超时机制。这种超时时间定义为会话在没有用户活动下维持激活状态的一段时间，即在上次最后收到的该会话 ID 的 HTTP 请求之后经过一段预设的时间后结束并销毁会话的机制。建议设置为 30min 超时
风险影响	设备长期登录账号可能出现账号泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	会话令牌为 opaque UUID 且长期存于浏览器 localStorage（非短时会话 Cookie）；实测在数小时的检测窗口内（含多次间隔空闲），同一登录态令牌持续可用、未被强制重新认证；且“安全策略”各页未见会话空闲超时/最大存活时长配置项，缺少有效的会话超时控制。
修复建议	设置合理的会话空闲超时（如 15~30 分钟）与最大存活时长，超时后服务端主动失效令牌；避免令牌长期驻留 localStorage。
备注	未做单独的长时间完全空闲后重放专项验证；结论基于缺空闲超时配置 + localStorage 长期存储与持续可用观测。

会话标识安全测试

测试编号	SESS-005
风险名称	会话标识安全测试
风险等级	中
功能要求	1、会话标识应具备唯一性和随机性。 2、会话标识应从一个可信系统，如在应用服务端创建，而不是在客户端创建。
风险影响	存在敏感信息泄露风险，攻击者猜测破解会话标识从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	会话令牌为可重用的 opaque UUID，且存在两类暴露：其一，令牌明文存于 localStorage，前端 JS 可读；其二，实测存在将 access_token 作为 URL 查询参数传递的接口（GET /api/user-center/users/getUser?access_token=...），易经服务器/代理访问日志、浏览器历史、Referer 泄露。
修复建议	令牌统一置于请求头（Authorization/自定义头），严禁经 URL 查询串传递；缩短令牌有效期并支持服务端主动吊销。
备注	

会话固定安全测试

测试编号	SESS-006
风险名称	会话固定安全测试
风险等级	—
功能要求	在用户提供的认证信息（如用户名和密码）、相应的权限级别发生变化时，服务器端应重新生成新会话标识，并强制失效之前的旧会话标识。
风险影响	存在敏感信息泄露风险，攻击者利用应用软件在服务器的会话标识固定不变机制，借助他人用相同的会话标识获取认证和授权，然后利用该会话标识劫持他人的会话以成功冒充他人，导致应用敏感信息泄露。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	登录成功后由服务端经 /api/user-center/oauth/token 新签发访问令牌，未沿用登录前的会话标识，未观察到会话固定迹象。
修复建议	
备注	未逐一比对登录前后全部会话标识，基于令牌颁发机制判定。

密钥安全

密钥存储安全测试

测试编号	Key-001
风险名称	密钥存储安全测试
风险等级	—
功能要求	密钥应禁止在代码中明文存储，应进行加密保护或通过环境变量调用
风险影响	一旦代码被泄露（例如通过版本控制系统、代码共享平台或恶意窃取），攻击者可以直接获取密钥，进而解密敏感数据，导致数据泄露。
测试依据	《ISO/IEC 27001:2022 信息安全管理体系》
测试结果	符合
截图说明	对前端 env.js 与主 bundle 进行敏感密钥检索，未发现硬编码的 RSA/私钥、对称加密密钥或 -----BEGIN ... KEY----- 等密钥材料。
修复建议	
备注	

AK/SK 专项安全测试

测试编号	Key-002
风险名称	AK/SK 专项安全测试
风险等级	中
功能要求	1、AK/SK 应遵循最小权限原则，按照不同功能模块分配不同权限的 AK/SK，避免使用具备云管理权限的 AK/SK 进行功能模块调用。 2、应记录 AK/SK 调用日志，要求日志内容可以溯源定位发起调用的具体功能模块。
风险影响	1、如果使用具备云管理权限的 AK/SK 进行功能模块调用，一旦该 AK/SK 被泄露

	或被恶意利用，攻击者可能获得对整个云环境的管理权限，从而对云资源进行未经授权的操作，如删除数据、修改配置、创建新的资源等，导致严重的安全事件。 2、没有记录 AK/SK 调用日志或日志信息不完整，当发生安全事件时，无法快速准确地溯源到发起调用的具体功能模块，增加了安全事件调查的难度和时间成本，可能导致无法及时采取有效的应对措施。
测试依据	《ISO/IEC 27001:2022 信息安全管理体系》
测试结果	不符合
截图说明	前端主 bundle 中硬编码高德地图 Web API Key（32 位十六进制，已脱敏，形如 833ba8ac...），随前端资源对任意访问者可见，可被他人提取并盗用第三方地图配额或用于伪造请求。
修复建议	第三方 AK/Key 不应硬编码于前端；改由后端代理调用或对 Key 配置 Referer/域名白名单与配额、来源限制，并轮换现有 Key。
备注	

异常处理

应用组件错误信息安全测试

测试编号	INFO-001
风险名称	应用组件错误信息安全测试
风险等级	—
功能要求	系统报错信息应不能输出中间件、开发框架、运行环境、数据库等产生的详细错误信息或业务敏感信息，如：个人信息、IP 信息、密码信息等。
风险影响	存在数据泄露、进一步扩大内网攻击范围等风险，详细的错误信息可能包含关于系统架构、代码逻辑、数据结构、数据库查询、文件路径、环境变量等敏感信息，攻击者可据此寻找潜在的安全漏洞，可能出现应用服务器权限被获取，造成应用敏感信息泄露以及内网横向攻击
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对不存在静态路径返回 openresty 标准 404；对不存在 API 路径网关返回 Spring Boot 默认错误 JSON（含 timestamp/path/error/requestId），仅暴露框架类型与请求标识，未回显异常堆栈、SQL 语句或内部绝对路径等高敏信息；未认证访问受保护接口返回 401。
修复建议	
备注	API 网关默认错误页暴露框架为轻微信息泄露（可优化）；未做深度错误注入。

业务安全

文件上传安全测试

测试编号	BUS-001
------	---------

风险名称	文件上传安全测试
风险等级	—
功能要求	文件上传功能应包含以下安全策略： 系统应不存在可以直接部署网页脚本的文件上传功能。 存储上传文件的 Web 应用服务应不存在脚本解析漏洞。 上传文件前应经过有效的身份验证。 文件上传的校验应服务端进行。 文件上传功能应存在有效的后缀白名单限制，且无法被突破。 文件上传的位置应无法通过参数进行指定或操控。 文件上传功能应不存在竞争上传问题。
风险影响	存在数据泄露、内网被进一步扩大范围攻击的风险，攻击者可利用文件上传漏洞远程部署木马，并获取服务器的 Web 执行权限，进而导致服务器的 webshell 被获取，造成应用敏感信息泄露以及内网横向攻击
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	已做低影响主动尝试：向导入接口 /api/ent-base/item/upload 提交伪装为 .jsp/.html 的良性文本文件（仅含测试标记、无可执行载荷），服务端返回统一异常未成功处理，未实现木马落地；因导入接口要求特定 Excel 模板格式，扩展名白名单/内容校验未能被充分穿透验证。
修复建议	
备注	未成功上传任何文件（无持久化）；受导入格式限制，恶意文件上传路径未被充分验证，据实标未测试。

文件下载安全测试

测试编号	BUS-002
风险名称	文件下载安全测试
风险等级	—
功能要求	在进行文件下载时，应确保下载权限设计合理（如：未授权下载、可读权限能绕过下载文件、下载非预期目录里文件）
风险影响	文件下载权限设计不当，攻击者可未授权下载或越权读取非预期目录文件，造成敏感数据泄露。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对文件下载接口 POST /api/ent-base/print/downloadFromOSS 注入路径遍历载荷（id=../../../../../../../../etc/passwd、ossUrl=..%2f..%2f..%2fetc%2fpasswd），服务端均返回统一异常、未回读任意文件，未发现路径遍历/任意文件下载迹象。
修复建议	
备注	抽样验证，未穷举全部下载接口的越权授权矩阵。

多线程竞争条件安全测试

测试编号	BUS-003
风险名称	多线程竞争条件安全测试
风险等级	—
功能要求	应用应不存在多线程竞争条件缺陷。对于业务端条件竞争的防范，一般的方法是设置锁。
风险影响	攻击者利用该漏洞可在积分不足情况执行恶意下单兑换商品。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	多线程竞争条件需对具体业务提交接口做并发压力/时序验证，属较高影响操作，本次生产环境未开展。
修复建议	
备注	非破坏性约束，据实标未测试。

重要数据类型验证安全测试（如：积分数值、商品数量、userid、供应商id篡改异常值）

测试编号	BUS-004
风险名称	重要数据类型验证安全测试（如：积分数值、商品数量、userid、供应商id篡改异常值）
风险等级	—
功能要求	应用业务逻辑功能应不存在数据类型验证缺陷。如将相关业务逻辑功能中的各个关键参数赋值为空值、0、负数值、超大数字、字符串、换行符、制表符、添加符号，以及将相关参数键值删除之后，出现的各类非预期结果。
风险影响	攻击者绕过篡改机制（如：签名、访问源IP等），利用应用数据类型验证缺陷，如将积分数值、商品数量、userid、供应商id进行删除或篡改，导致获取非预期恶意收益或权限。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	已对查询接口做低影响类型/边界验证：pageAccount 的 currentPage=-1/pageSize=-5 被服务端安全钳制、pageSize="abc" 返回统一异常，但 pageSize=999999 未做上限限制被原样接受（存在大批量数据拉取/资源消耗的轻微风险）。业务写接口的金额/数量/userid/供应商id等异常值篡改属较高影响操作，且本租户业务数据为空，未开展。
修复建议	
备注	查询参数类型校验基本正常（pageSize 缺上限为可优化点）；业务写参数篡改因非破坏性约束未测试。

业务流程非预期执行安全测试

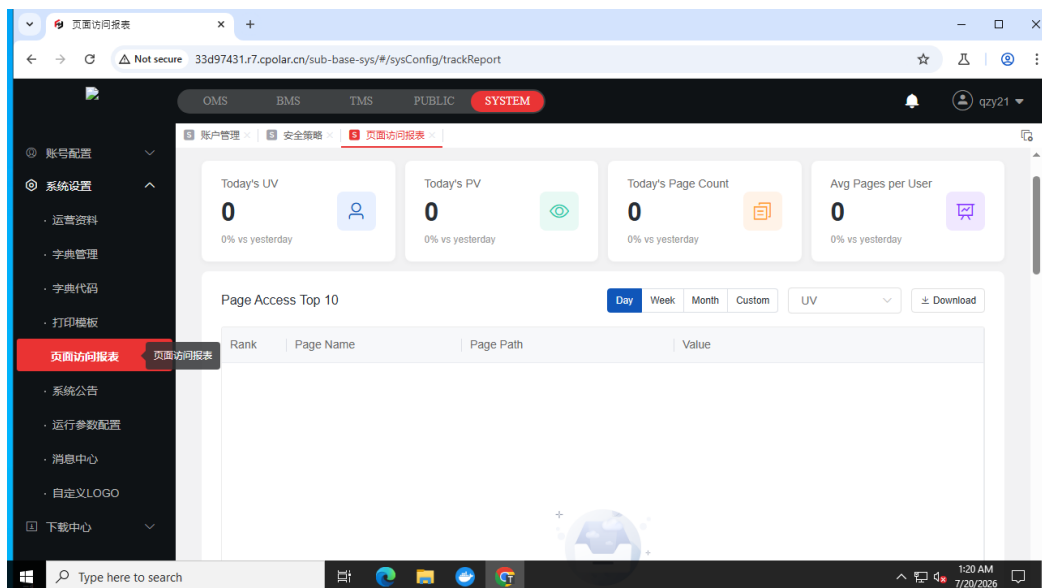
测试编号	BUS-005
风险名称	业务流程非预期执行安全测试
风险等级	—
功能要求	所在业务流程执行过程中，应具备防护机制来保证其遵循正常流程设计执行，

	所在的业务流程阶段不能被用户恶意非预期执行。
风险影响	攻击者非预期恶意打乱执行业务流程，可导致恶意。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	业务流程非预期执行需围绕完整业务链路做跳步/越阶提交验证，本次未在生产环境开展破坏性流程测试。
修复建议	
备注	非破坏性约束，据实标未测试。

日志审计

基础日志审计功能安全测试

测试编号	AUD-001
风险名称	基础日志审计功能安全测试
风险等级	—
功能要求	1、应用应具备安全审计日志记录功能 2、安全审计日志应无法被修改、删除 3、安全审计日志应提供日志数据统计、查询功能
风险影响	存在安全事件无法定位溯源的风险，缺少安全审计日志，会导致出现安全事件后，不能及时溯源定位问题账号以及问题功能，进而造成更大损失
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	被测租户管理员角色 UI 中仅见“页面访问报表”（UV/PV 前端访问量统计，见图），无安全操作审计模块入口。经接口层验证，平台存在操作日志查询接口（POST /api/ent-base/sys-operation-log/v1/queryByRelationCode，当前角色可调用、对测试 relationCode 返回空集），说明平台层具备操作日志能力，但其对登录/改密/导出/权限变更等安全事件的覆盖范围与内容无法从被测账号确认。
修复建议	
备注	基础审计能力存在（操作日志接口 + 账户 loginCount/loginIp 字段）；完整安全事件覆盖与审计查询 UI 需平台超管确认（见 AUD-002/003）。



图：系统提供页面访问量统计（UV/PV）；平台另具操作日志接口

基础日志审计内容安全测试

测试编号	AUD-002
风险名称	基础日志审计内容安全测试
风险等级	—
功能要求	1、安全审计日志应包含：登录日志、操作日志 （1）登录日志：记录用户登录、登出、及登录结果等，应包含管理员账号，登录日志应包含登录时间、登录 IP、登录账号和登录结果 （2）操作日志：记录用户对功能模块访问及操作信息（如：查看、修改和导出等），访问日志应包含操作事件、操作账号、源 IP、访问接口和操作动作等 2、针对不同业务场景，可能还存在其他日志类型，如账号积分流水日志等
风险影响	缺少安全审计日志或日志信息不全，会导致出现安全事件后，不能有效溯源攻击路径，定位风险影响等
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	因被测角色未见安全审计日志功能，无法查看审计记录是否包含时间、来源 IP、操作账号、操作对象、结果等要素。
修复建议	
备注	据实标未测试。

基础日志审计存储安全测试

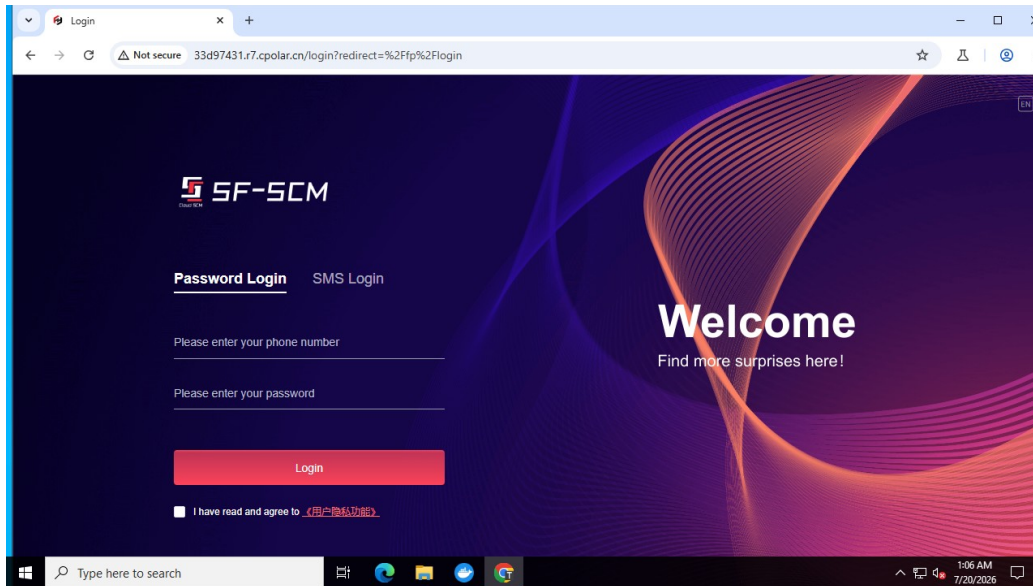
测试编号	AUD-003
风险名称	基础日志审计存储安全测试
风险等级	—

功能要求	安全审计日志存储时间应达到6个月或以上
风险影响	存在安全事件无法定位溯源的风险，安全审计日志存储时间较短，会导致出现入侵事件后，无法有效溯源攻击路径，进而造成更大损失
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	未测试
截图说明	无法从被测账号确认审计日志的存储方式、留存周期与防篡改/防删除措施。
修复建议	
备注	据实标未测试。

数据安全

加密传输安全测试

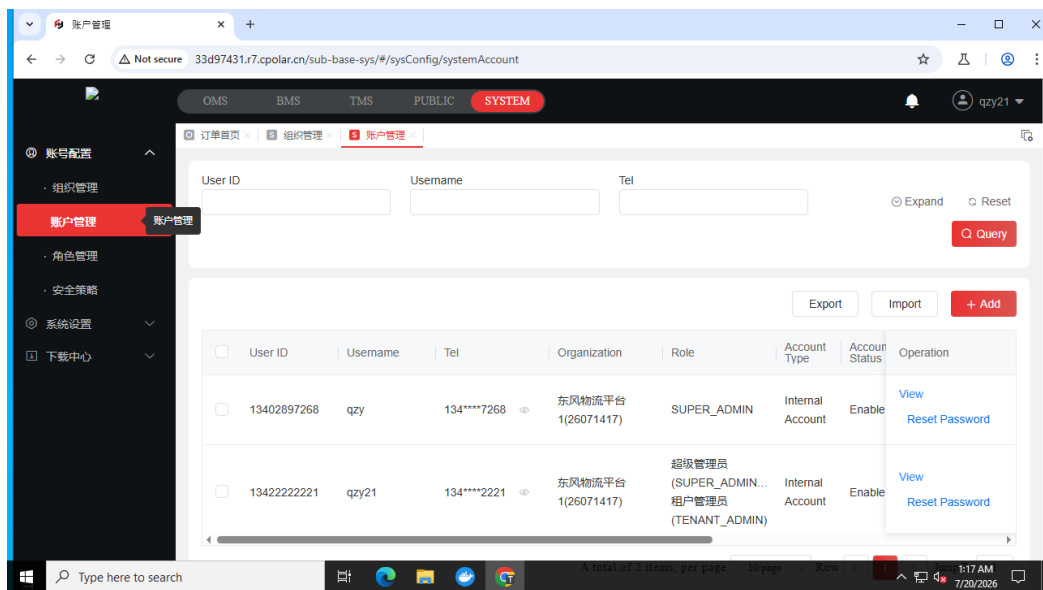
测试编号	DATA-001
风险名称	加密传输安全测试
风险等级	高
功能要求	应用应对数据通信过程中的敏感数据进行加密，如：汽车业务-车辆行驶轨迹信息、汽车充电网的运行数据、vin 码，出行业务-航班车票信息、特定住宿信息，金融业务-个人收入明细、征信信息、支付标记信息、银行卡号，特定身份信息-身份证件号码。应使用 SHA-256 或更强的加密技术加密传输
风险影响	存在敏感信息泄露风险，数据在传输过程中，如果未经加密，就容易被攻击者截获。这些敏感信息包括但不限于用户个人信息、企业商业机密、金融交易数据等，一旦泄露，将给用户和企业带来重大损失。
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	不符合
截图说明	目标应用全站以 HTTP 明文对外提供服务（用户浏览器实际以 http://内网 IP:8003 访问，浏览器提示 Not secure，非隧道所致）。实测登录请求 POST /api/user-center/oauth/token 的请求体以明文（URL 编码）提交账号与口令字段（口令值已脱敏），会话令牌亦经明文信道传输，可被链路中间人嗅探/窃取。
修复建议	全站启用 HTTPS 并强制 HTTP 跳转 HTTPS、开启 HSTS；口令在传输前结合 TLS 保护，敏感字段可叠加应用层加密。
备注	



图：登录页经 HTTP 明文访问（浏览器 Not secure）

数据脱敏展示安全测试

测试编号	DATA-002
风险名称	数据脱敏展示安全测试
风险等级	中
功能要求	应用页面敏感信息应默认脱敏显示，如：汽车业务-车辆行驶轨迹信息、汽车充电网的运行数据、vin 码，出行业务-航班车票信息、特定住宿信息，金融业务-个人收入明细、征信信息、支付标记信息、银行卡号，特定身份信息-身份证件号码。可以通过点击“显示详情”按钮进行逐个明文显示。
风险影响	存在敏感信息泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取敏感信息
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	不符合
截图说明	“账户管理”列表对“Tel(手机号)”列做了掩码展示（134***xxxx），但同页“User ID”列以完整明文展示用户手机号（用户账号即手机号），脱敏不一致。经接口层确认：POST /api/user-center/account/pageAccount 响应中 phone 字段已掩码（134***xxxx），但 userName 字段以完整明文返回手机号，说明掩码仅为前端展示层面、后端仍下发完整个人信息。
修复建议	对同一敏感字段在全部展示位置保持一致脱敏；确需展示完整值时按需授权 + 操作留痕。
备注	



图：Tel 列已掩码但 User ID 列明文展示完整手机号

数据导出安全测试

测试编号	DATA-003
风险名称	数据导出安全测试
风险等级	—
功能要求	1、二级系统导出信息包含个人信息，应支持文件加密导出 2、三级系统及三级以上系统数据导出应通过审批流程管控，同时日志记录导出行为，导出信息包含个人信息，应支持文件加密导出
风险影响	可能存在敏感数据泄露风险，攻击者获取应用权限后通过数据导出，获取大量个人信息、重要业务数据，将给用户和企业带来重大损失。
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	符合
截图说明	实测账户导出为服务端异步任务模式：点击导出经 POST /api/data-center/downloadRecord/addTask (bizType=USER_ACCOUNT_REPORT) 提交任务，在“下载中心-导出任务”中生成并下载；导出记录经 downloadRecord/page 按租户隔离展示、需认证，并带 creatorCode/createTime 等留痕字段，具备鉴权与导出留痕控制。
修复建议	
备注	为控制真实个人信息外泄，未将导出文件落地检测端；又因本环境异步制表未在测试窗口内完成，导出文件对手机号等字段是否脱敏未能最终确认；结合 DATA-002（后端 userName 返回完整手机号），建议业务方重点复核导出文件字段脱敏。

常见漏洞

HTTPS 安全测试

测试编号	VULN-001
风险名称	HTTPS 安全测试
风险等级	中
功能要求	1、要求使用 https 协议进行加密传输。若 HTTP 协议在传输数据时未进行加密，则所有在网络中传输的信息都是以明文形式存在，任何能够捕获网络流量的中间人都可以轻易读取这些数据，导致信息泄露。 2、要求使用 1.2 或更高版本的 TLS 协议。低版本的 TLS 协议由于设计缺陷、已知漏洞、过时的加密算法支持，它们的安全性已经不足以应对现代威胁，继续使用可能使数据传输面临以下风险： （1）已知漏洞利用：旧版本的 TLS 可能存在已知安全漏洞，如 BEAST、POODLE、LUCKY13 等，攻击者可以利用这些漏洞解密或篡改加密通信 （2）弱加密算法：早期的 TLS 版本可能支持过时或已被破解的加密算法（如 RC4、DES、MD5 等），这些算法提供的加密强度不足以抵抗现代计算能力下的攻击，可能导致数据轻易被破解 （3）缺乏 Perfect Forward Secrecy (PFS)：早期 TLS 版本对 PFS 的支持有限。PFS 旨在即使长期密钥被泄露，也无法追溯解密之前的历史会话。缺乏 PFS 意味着一旦主密钥被破解，所有使用该密钥保护的过去会话都可能被解密 （4）不满足现行安全标准：随着安全标准的更新，如 PCI DSS、NIST 等组织已经要求弃用不安全的 TLS 版本。继续使用可能违反合规要求，导致法律责任或信誉损失 （5）浏览器与操作系统弃用：主流浏览器和操作系统厂商（如 Google、Mozilla、Microsoft 等）已逐渐停止支持不安全的 TLS 版本，用户使用老旧浏览器访问这类网站时可能会遇到警告或无法连接的问题 不安全的 TLS 协议主要包括： TLS 1.0：发布于 1999 年，存在诸多已知漏洞和使用了较弱的加密算法 TLS 1.1：发布于 2006 年，虽然比 TLS 1.0 有所改进，但仍存在一些安全缺陷，如部分加密套件的安全性不足
风险影响	存在信息泄露的风险： 1、未使用 HTTPS 协议，则所有在网络中传输的信息都是以明文形式存在，任何能够捕获网络流量的中间人都可以轻易读取这些数据，导致信息泄露 2、低版本的 TLS 协议由于设计缺陷、过时的加密算法支持，存在已知安全漏洞，如 BEAST、POODLE、LUCKY13 等，攻击者可以利用这些漏洞解密或篡改加密通信
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	目标未部署 HTTPS，全站 HTTP 明文，且根路径请求未见 HTTP→HTTPS 跳转（返回 200），响应亦无 Strict-Transport-Security(HSTS) 头。
修复建议	部署有效 TLS 证书并全站启用 HTTPS，配置 HTTP 强制跳转 HTTPS 与 HSTS。
备注	

HTTP 高危请求方法安全测试

测试编号	VULN-002
风险名称	HTTP 高危请求方法安全测试
风险等级	—
功能要求	要求应用服务使用安全的 http 请求方法，如下请求方法应该被禁止使用： PUT:这个方法允许客户端向 web 服务器上传新的文件。攻击者可以利用他来上传恶意文件（比如一个 asp 文件通过调用 cmd.exe 来执行命令），或者简单使用受害者服务器作为文件仓库（若存在业务需要，请说明原因并做好权限控制） DELETE:这个方法允许客户端删除 web 服务器上的一个文件。攻击者能利用他简单直接破坏网站或者实施拒绝服务攻击（若存在业务需要，请说明原因并做好权限控制） CONNECT:这个方法允许客户端使用 web 服务器作为代理 TRACE:这个方法简单返回客户端发送给服务器的所有信息，主要用于调试目的，后被发现能够用于实施 XST 攻击
风险影响	存在信息泄露的风险，不安全的 http 请求方法可能造成传恶意文件上传、XST 攻击等安全问题，攻击者通过上传后门文件窃取服务器权限，造成敏感数据泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对接口发起 OPTIONS/TRACE/PUT/DELETE/PATCH 等方法测试，服务端均返回 405 Method Not Allowed，未开放高危 HTTP 方法。
修复建议	
备注	

弱口令安全测试

测试编号	VULN-003
风险名称	弱口令安全测试
风险等级	—
功能要求	系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种
风险影响	弱口令漏洞是指用户在设置账户密码时采用了复杂度较低、易于被他人猜测或破解的口令。这种漏洞的存在使得攻击者能够相对容易地获取账户的访问权限，进而可能对系统、应用程序或敏感数据造成未经授权的访问、修改、泄露甚至破坏
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	系统已强制强口令策略（最小长度 10 位、需同时包含数字与字母、更新周期约 90 天、历史口令不得重复，见 AUTH-008），并启用登录失败锁定（5 次 / 15 分钟，见 AUTH-005），弱口令无法被设置、在线爆破受有效抑制。遵循最小影响原则未实施口令爆破。
修复建议	

备注	基于已启用的强口令策略与失败锁定判定；预置固定初始口令风险另见 AUTH-004。
----	---

XSS 安全测试

测试编号	VULN-004
风险名称	XSS 安全测试
风险等级	—
功能要求	XSS 全称为 Cross Site Scripting，为了和 CSS 分开简写为 XSS，中文名为跨站脚本。该漏洞发生在用户端，是指在渲染过程中发生了不在预期过程中的 JavaScript 代码执行。XSS 通常被用于获取 Cookie、以受攻击者的身份进行操作等行为。 为了有效防范 XSS 漏洞，应用应遵循以下要求： 1、输入过滤，避免 XSS 的方法之一主要是将用户输入的内容进行过滤。对所有用户提交内容进行可靠的输入验证，包括对 URL、查询关键字、POST 数据等，仅接受指定长度范围内、采用适当格式、采用所预期的字符的内容提交，对其他的一律过滤(客户端和服务端都要) 2、输出转义，例如：往 HTML 标签之间插入不可信数据的时候，首先要做的就是对不可信数据进行 HTML Entity 编码 3、使用 HttpOnly Cookie，将重要的 cookie 标记为 httponly，这样的话当浏览器向 Web 服务器发起请求的时就会带上 cookie 字段，但是在 js 脚本中却不能访问这个 cookie，这样就避免了 XSS 攻击利用 JavaScript 的 document.cookie 获取 cookie
风险影响	存在对造成用户负面影响的风险，攻击者利用 XSS 漏洞窃取敏感信息，如用户的 cookie、会话令牌等，用于后续的攻击。或篡改页面内容，如插入恶意广告、钓鱼链接等，误导用户。亦或执行恶意操作，如以用户身份进行发帖、转账等恶意行为。造成用户负面影响。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	未测试
截图说明	已做低影响反射型抽样：向网关注入 <script>alert(1)</script> 路径，服务端仅返回 JSON 错误、未回显可执行载荷，且前端为 Vue（默认转义），反射型 XSS 抽样未发现；存储型 XSS（如 nickName 等字段）需写入账号/业务数据，属较高影响操作，未开展。会话令牌存于 localStorage（见 SESS-001/005），一旦存在 XSS 影响将被放大。
修复建议	
备注	反射型抽样无回显；存储型因需写入业务数据、非破坏性约束未测试，据实标未测试。

XXE 安全测试

测试编号	VULN-005
风险名称	XXE 安全测试
风险等级	—

功能要求	XXE (XML External Entity Injection, XML 外部实体注入) 漏洞是一种影响解析 XML 文档的应用程序的安全漏洞。此漏洞源于应用程序未能正确或安全地处理 XML 文档中的外部实体引用。 为了有效防范 XXE 漏洞, 应用应遵循以下要求: 1、禁用外部实体加载: 在解析 XML 时, 首先且最重要的是禁止加载外部实体。大多数 XML 解析器都提供了配置选项来禁用此功能。 2、使用安全的解析器配置: 确保 XML 解析器以最安全的模式运行, 限制对外部 DTD (文档类型定义) 和实体的解析。在可行的情况下, 使用那些默认禁用外部实体加载的库或 API。 3、输入验证与过滤: 对所有用户提交的 XML 数据进行严格的输入验证, 避免非法或恶意的 XML 结构。使用白名单方式验证 XML 结构, 只允许预期格式的数据通过。
风险影响	存在数据泄露风险, 攻击者利用 XXE 漏洞执行 SSRF 攻击, 通过实体指向内部网络或服务的 URI, 间接获取内部系统的敏感信息, 造成数据泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不涉及
截图说明	可访问接口均以 JSON 交互 (Content-Type: application/json), 未发现接受 XML 输入的解析入口, XXE 不适用于当前接口形态。
修复建议	
备注	未发现 XML 解析入口, 列为不涉及。

CSRF 安全测试

测试编号	VULN-006
风险名称	CSRF 安全测试
风险等级	—
功能要求	CSRF (Cross-Site Request Forgery) 跨站请求伪造, 是指攻击者通过构建一个恶意网页, 诱使已经登录了目标网站的用户访问这个恶意网页, 利用用户的登录状态, 在用户不知情的情况下执行攻击者预设的操作。 这种攻击主要是利用了网站对用户身份验证后产生的 cookie 或其他认证信息 (如 JWT Token 等) 在一定有效期内维持用户身份的特性。攻击者并不能获取到这些认证信息, 但他们可以诱导已登录的用户发送一个请求到目标站点, 而该请求是由攻击者精心构造的, 旨在进行非法操作, 比如转账、修改密码、发布内容等。 为了有效防范 CSRF 漏洞, 应用应遵循以下要求:
风险影响	存在应用信息泄露风险, 攻击者利用用户的登录状态, 在用户不知情的情况下执行攻击者预设的操作, 如修改密码、发布内容等, 可能造成账号被窃取, 应用信息泄露风险。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	系统认证采用经 Authorization 头传递的 Bearer 令牌 (存于 localStorage, 非 Cookie 自动携带), 跨站请求无法自动携带用户凭证, 传统 CSRF 风险较低。

修复建议	
备注	需结合 SESS-002 的 CORS 配置整改，避免跨域携带凭证读取数据。

SSRF 安全测试

测试编号	VULN-007
风险名称	SSRF 安全测试
风险等级	—
功能要求	应用软件应不存在 SSRF 漏洞。SSRF(Server-Side Request Forgery:服务器端请求伪造) 是一种由攻击者构造形成由服务端发起请求的一个安全漏洞。SSRF 漏洞主要发生在服务器端，当服务器在处理用户请求时，没有对用户输入的 URL 进行有效的验证和过滤，导致攻击者可以构造恶意的 URL，让服务器发起非预期的请求。这些请求可能指向内部网络，如数据库、文件服务器等，也可能指向外部网络，如其他网站、开放端口等。一旦攻击成功，攻击者可以获取到服务器的敏感信息，甚至可能进一步利用这些信息对内部网络进行攻击。 为了有效防范 SSRF 漏洞，应用应遵循以下要求： 1、输入验证和过滤：对所有用户输入进行严格的验证和过滤，确保输入只包含预期的字符和格式。避免直接拼接用户输入到 URL 或请求中，使用参数化查询或安全的库来处理输入 2、限制请求的目标：限制服务器能够请求的目标地址范围，只允许访问预定的白名单地址。如果需要访问内部资源，确保使用安全的内部接口，并限制访问权限
风险影响	SSRF 漏洞的影响范围广泛，存在的风险包括： 敏感信息泄露：攻击者可以利用 SSRF 漏洞获取数据库、文件服务器等内部资源的敏感信息，如用户数据、配置文件等。 被执行恶意操作：攻击者可以利用 SSRF 漏洞执行恶意操作，如远程命令执行、文件上传等，进一步危害系统的安全。 应用系统无法正常提供服务：攻击者可以利用 SSRF 漏洞对目标服务器发起大量的恶意请求，导致服务器资源耗尽，无法正常提供服务。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对地址解析接口 GET /api/oms-service/applet/address/parseAddress 注入 http://example.com/ 与 http://127.0.0.1:8003/ 等 URL 载荷，服务端将其作为非法地址直接返回失败、未发起对目标 URL 的外发请求；检阅可访问接口未发现用户可控的 URL 拉取型 SSRF 汇聚点。
修复建议	
备注	抽样主动测试，接口对 URL 输入不发起外部请求；未穷举全部接口。

SQL 注入安全测试

测试编号	VULN-008
风险名称	SQL 注入安全测试
风险等级	—

功能要求	SQL 注入是一种常见的网络攻击手法，它利用了 Web 应用程序对用户输入数据处理不当的漏洞，让攻击者能够在数据库查询中插入恶意的 SQL 代码。这种攻击可以让攻击者未经授权地访问、修改或删除数据库中的数据，甚至完全控制数据库服务器。 为了有效防范 SQL 注入漏洞，应用应遵循以下要求： 1、使用 PreparedStatement 或者参数化查询能够有效地防止 SQL 注入 2、对所有用户输入的数据进行转义处理，尤其是对于可能用于分隔字符串或改变 SQL 语句结构的特殊字符（如单引号、双引号、分号、注释符等），将其转换为安全的形式，使其无法被解释为 SQL 命令的一部分 3、对用户的输入进行严格的验证，例如检查输入的数据类型、长度、格式是否符合预期，可以采用白名单方式，只允许特定字符或格式的输入
风险影响	存在被执行恶意操作的风险，成功的 SQL 注入攻击可以从数据库中读取敏感数据、修改数据库数据（插入/更新/删除）、对数据库执行管理操作（例如关闭 DBMS）、将后门文件写入文件系统，在某些情况下，还可以在操作系统执行恶意命令
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对账户查询接口 POST /api/user-center/account/pageAccount 的 userName 搜索参数注入单引号、' OR '1'='1、'1' -- 等错误/布尔型探测载荷，响应与基线完全一致（无 SQL 报错、无结果集变化），未发现 SQL 注入迹象（参数化查询）。
修复建议	
备注	抽样主动测试，限于可访问的典型查询接口，未穷举全部参数。

LDAP 注入安全测试

测试编号	VULN-009
风险名称	LDAP 注入安全测试
风险等级	—
功能要求	LDAP (Lightweight Directory Access Protocol)，轻量级目录访问协议，是一种在线目录访问协议，主要用于目录中资源的搜索和查询。如果在用户可控的输入中没有对 LDAP 语法进行除去或引用，那么生成的 LDAP 查询可能会导致将这些输入解释为 LDAP 而不是普通用户数据。这可用于修改查询逻辑以绕过安全性检查，或者插入其他用于修改后端数据库的语句，可能包括执行系统命令。 为了有效防范 LDAP 注入漏洞，应用应遵循以下要求： 1. 使用不允许此弱点出现的经过审核的库或框架，或提供更容易避免此弱点的构造。 2. 使用自动实施数据和代码之间的分离的结构化机制。这些机制也许能够自动提供相关引用、编码和验证，而不是依赖于开发者在生成输出的每一处提供此能力。 3. 使用完成必要任务所需的最低特权来运行代码。 4. 如果在有风险的情况下仍需要使用动态生成的查询字符串或命令，建议对参

	数正确地加引号并将这些参数中的任何特殊字符转义。 5. 使用“接受已知善意”输入验证策略：严格遵守规范的可接受输入的白名单。拒绝没有严格遵守规范的任何输入，或者将其变换为严格遵守规范的内容。不要完全依赖于通过黑名单检测恶意或格式错误的输入。但是，黑名单可以帮助检测潜在攻击，或者确定哪些输入由于格式严重错误而应直接拒绝。
风险影响	存在被执行恶意操作的风险，成功的 LDAP 注入攻击可以从 LDAP 目录树下的数据库中读取敏感数据、修改数据库数据（插入/更新/删除）、对数据库执行管理操作（例如关闭 DBMS）、将后门文件写入文件系统，在某些情况下，还可以在操作系统执行恶意命令
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不涉及
截图说明	系统认证基于手机号+口令的 OAuth2 令牌端点（账号体系基于数据库），未发现 LDAP 目录查询入口，LDAP 注入不适用。
修复建议	
备注	未发现 LDAP 入口，列为不涉及。

文件包含安全测试

测试编号	VULN-010
风险名称	文件包含安全测试
风险等级	—
功能要求	文件包含漏洞是 Web 应用程序中的一种常见安全漏洞，它允许攻击者通过操纵文件包含功能，让应用程序加载并执行了非预期的恶意文件。这种漏洞通常发生在动态网页编程中，当程序设计时为了提高代码复用性，会使用特定的函数或语句（如 PHP 中的 include(), require(), 或 JSP 中的<jsp:include>）来包含外部文件。如果对外部文件的路径没有进行充分的验证或过滤，攻击者就可以通过精心构造的输入来控制这些包含函数的参数，从而引入恶意代码。 为了有效防范文件包含漏洞，应用应遵循以下要求： 1、严格限制文件包含函数的参数，确保只能从预定义的、安全的目录中包含文件。 2、对用户提交的包含文件请求进行严格的过滤和校验，去除危险字符，如../等路径遍历字符，以及不必要的协议头如 http://、ftp://等
风险影响	存在信息泄露的风险，攻击者通过恶意构造的输入，诱使服务器加载并执行非预期的文件，从而导致远程命令执行、信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对文件下载/读取相关接口（POST /api/ent-base/print/downloadFromOSS）注入路径遍历/本地文件包含载荷（../../../../../../../../etc/passwd 等），服务端返回统一异常、未回读任意文件，未发现文件包含/路径遍历迹象。
修复建议	
备注	抽样主动测试，与 BUS-002 共享证据。

反序列化安全测试

测试编号	VULN-011
风险名称	反序列化安全测试
风险等级	—
功能要求	反序列化漏洞是一种安全漏洞，出现在使用序列化和反序列化功能的应用程序中，尤其是在处理来自不可信来源的序列化数据时。序列化是将对象转换为一系列字节（如二进制数据或文本字符串），以便存储或通过网络传输；而反序列化则是将这些字节流还原为原始对象的过程。当应用程序对用户提供的数据执行反序列化操作时，如果缺乏足够的验证和安全控制，恶意攻击者就可能利用特制的序列化数据来执行未经授权的操作。 为了有效防范反序列化漏洞，应用应遵循以下要求： 1、输入验证与数据过滤： 对所有反序列化的输入数据进行严格的验证，确保它们来自可信的源头并且格式正确。实施输入过滤，拒绝不满足预期格式或包含潜在恶意数据的输入。 2、使用白名单： 实施类型白名单，仅允许特定类或类型的对象被反序列化。这样可以阻止恶意对象的创建。 3、禁用不需要的类和库： 评估并禁用任何不必要或可能引入风险的类库，特别是那些具有已知漏洞的类库。 4、限制功能与权限： 运行应用程序在最低权限环境下，确保即使发生反序列化攻击，攻击者也无法执行高权限操作。 5、序列化格式的选择： 使用更安全的序列化格式，如 Protocol Buffers 或 MessagePack，这些格式通常比传统的 Java 序列化更安全，因为它们提供了更细粒度的控制。 6、保持软件及库的更新： 定期更新所有的软件框架和第三方库，以获取最新的安全修复和补丁。 7、安全配置： 对于像 Fastjson 这样的库，确保遵循其安全配置指南，禁用不安全的功能，如自动类型转换。
风险影响	存在信息系统被远控的风险，攻击者可以通过构造含有恶意指令或数据的序列化字符串，将恶意序列化数据注入到目标应用程序的反序列化流程中，从而实现远程命令执行
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	接口均以 JSON（Jackson）交互；向账户接口提交 Content-Type: application/x-java-serialized-object 的非 JSON 字节体，服务端直接返回统一异常、未观察到原生反序列化处理，未发现反序列化汇聚点。
修复建议	
备注	抽样主动测试；Jackson 多态深度反序列化未穷举，未发现原生序列化入口。

远程命令执行安全测试

测试编号	VULN-012
风险名称	远程命令执行安全测试
风险等级	—
功能要求	远程命令执行漏洞（Remote Command Execution，简称 RCE）是一种常见的安全漏洞，它允许攻击者通过向目标系统发送恶意命令，从而远程执行系统命令或代码。 为了有效远程命令执行漏洞，应用应遵循以下要求： 1、严格输入验证：对所有用户输入进行严格的验证，确保输入内容符合预期且不含恶意代码。 2、输入过滤：使用合适的过滤机制，如黑名单（禁止特定字符或模式）和白名单（仅允许特定字符或模式），来过滤和清理用户输入。 3、避免使用危险函数：尽量避免在代码中直接使用能够执行系统命令的函数，如 PHP 中的 <code>exec()</code>，<code>system()</code>，<code>passthru()</code>，<code>shell_exec()</code> 等。 4、最小权限原则：确保应用程序和服务以最小权限运行，即使发生漏洞，攻击者也无法获得过高的权限。
风险影响	攻击者通过向目标系统发送恶意命令，从而远程执行系统命令或代码，可能导致系统被完全控制、数据泄露、服务中断等严重后果。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	向账户搜索参数注入良性命令注入标记（ <code>\$(sleep 0);id`whoami`</code> ），服务端将其作为普通搜索字符串处理（返回无匹配结果、响应耗时无 <code>sleep</code> 迹象），未发现命令执行迹象。
修复建议	
备注	抽样主动测试，未发现命令注入/执行汇聚点。

暗链安全测试

测试编号	VULN-013
风险名称	暗链安全测试
风险等级	—
功能要求	暗链，又称为黑链或隐蔽链接（hidden links），是一种常见的网络安全风险。暗链的主要目的是通过非正当手段为攻击者的网站增加外部链接，暗链可能链接到含有恶意软件、钓鱼网站或其他不安全的网站，对访问这些链接的用户构成安全威胁。 为了有效防范暗链，应用应遵循以下要求： 定期检查网站源代码： 定期审查网站的 HTML 源代码，特别是首页和权重较高的页面，查找任何未知或可疑的链接。这包括检查隐藏的 CSS 样式（如 <code>display:none</code>）或与背景颜色相同的文字链接。 保持更新和维护： 保持网站平台、插件、主题和所有软件组件的最新状态，及时安装安全更新和补丁，修复已知漏洞。

	3、备份与恢复计划： 定期备份网站数据和文件，万一遭受攻击，能够迅速恢复到未被篡改的状态。
风险影响	存在信息泄露的风险，被植入恶意链接可能造成用户信息泄露，影响用户体验
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	查看应用页面源码与前端资源，未发现植入的暗链、异常隐藏外链或非法跳转。
修复建议	
备注	

开发框架、中间件安全测试

测试编号	VULN-014
风险名称	开发框架、中间件安全测试
风险等级	—
功能要求	开发框架与中间件构成了现代应用程序和服务的基石，极大地赋能开发者，提供了高效且便捷的开发解决方案。然而，在实际搭建过程中，由于兼容旧有组件的需求、个人编程习惯偏好等因素，开发团队有时未能采用最新且更为安全的版本。这一现状不幸留下了隐患，使得应用服务中潜藏了已知的历史安全漏洞，增加了被恶意攻击的风险。 为了有效防范开发框架、中间件漏洞，应用应遵循以下要求： 安全性优先：在项目规划初期即纳入安全考量，优先选用具有良好安全记录和支持的组件。 定期更新：定期检查并升级至框架与中间件的最新安全版本，以封堵已知漏洞。 3、安全配置：遵循最佳安全实践，确保框架和中间件的配置是安全的，不要依赖默认配置。
风险影响	存在敏感信息泄露风险，攻击者可利用漏洞获取服务器权限，造成敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	前端 Web 服务为 openresty（未回显版本）；后端经 404 默认错误 JSON 结构确认为 Spring Boot。针对最具影响的 Spring 框架 RCE（Spring4Shell / CVE-2022-22965）作无写入副作用的安全探测（class.* 绑定参数），未观察到中招迹象；结合 actuator/swagger/druid 等未对外暴露（见 VULN-015）。
修复建议	
备注	抽样主动探测未发现高危框架漏洞中招；因无法获取组件精确小版本，未能穷举全部 CVE，建议由资产方核对版本并纳入 SCA 例行扫描。

未授权访问安全测试

测试编号	VULN-015
风险名称	未授权访问安全测试

风险等级	—
功能要求	应用软件应不存在常见的未授权访问漏洞，如 Spring Boot Actuator 未授权访问漏洞，Spring Eureka 未授权访问漏洞，MongoDB 未授权访问漏洞，swagger 未授权访问漏洞，Hadoop 未授权访问漏洞等。
风险影响	存在敏感信息泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	未认证访问受保护接口（如 GET /api/user-center/users/getUser 不带令牌）返回 401；访问应用页面跳转登录；actuator/swagger/druid 等管理端点未对外暴露，未发现明显未授权访问点。
修复建议	
备注	未穷举全部接口，基于抽样与关键端点验证。

敏感信息泄露安全测试

测试编号	VULN-016
风险名称	敏感信息泄露安全测试
风险等级	中
功能要求	应用软件应不存在下列敏感信息泄露风险 1、源代码泄露：公开暴露的源代码文件（如.php，.jsp，.py，.asp等）可能包含敏感信息，如数据库连接字符串、API 密钥、硬编码凭据等。 2、配置文件泄露：包含敏感配置信息的文件（如.env，config.php，web.config等）被公开，可能泄露数据库凭据、加密密钥、系统设置等。 3、备份文件泄露：未受保护的数据库、系统或网站备份文件可能包含大量敏感数据，如用户信息、交易记录、内部文档等。 4、未授权访问的管理界面：如后台管理面板、控制台等，攻击者可能通过默认或弱口令进入，直接操控系统。 5、默认示例文件泄露：如安装脚本、示例页面、测试数据等，它们可能提供有关系统架构、软件版本或配置的信息，也可能成为攻击入口。
风险影响	存在应用服务敏感信息泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	综合发现多处敏感信息暴露：账户列表 User ID 列明文展示完整手机号（个人信息）；access_token 经 URL 查询参数传递；前端 env.js/bundle 暴露内部微服务前缀、内部对象存储地址与第三方地图 Key。
修复建议	对个人信息一致脱敏；令牌禁止走 URL；前端最小化暴露内部服务信息与第三方凭证。
备注	详见 DATA-002、SESS-005、FRON-002、Key-002。

处理用时安全测试

测试编号	VULN-017
风险名称	处理用时安全测试

风险等级	—
功能要求	应用软件应不存在拒绝服务漏洞，如查询时间更改导致的拒绝服务漏洞、修改尺寸大小造成拒绝服务漏洞、退出登录处存在的拒绝服务漏洞等
风险影响	存在应用软件无法正常提供服务的风险，影响用户体验
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对可访问只读接口多次采样单次耗时，各接口响应稳定在约 300~470ms、无显著时序差异；登录失败返回通用错误（降低基于耗时的用户枚举风险），未发现可被利用的明显时序侧信道。
修复建议	
备注	抽样单次耗时无显著差异；为避免账号锁定，未做高强度统计时序攻击。